

ISMS ROLES & RESPONSIBILITIES

CONFIDENTIAL

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Annually	23th – February - 2026	

Document Purpose

This document defines the roles and responsibilities required to effectively implement and maintain an Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 standards. It outlines the allocation of accountability across the organization to ensure proper governance, risk management, and operational security.

Scope

This document applies to all employees, contractors, and third-party vendors involved in managing, implementing, and maintaining the ISMS at Saudi EXIM Bank.

Key Roles and Responsibilities

Board of Directors

- **Governance & Oversight**
 - Approve the overall cybersecurity strategy and ISMS framework.
 - Ensure that cybersecurity aligns with business objectives and regulatory requirements.
- **Risk Appetite & Policy Approval**
 - Define the bank's risk appetite and tolerance for cyber threats.
 - Approve critical security policies and ensure they are enforced across the organization.
- **Resource Allocation**
 - Ensure sufficient budget and resources are available for cybersecurity initiatives, ISMS implementation, and continuous improvement.
- **Accountability & Reporting**
 - Receive regular reports from the CISO or Information Security Manager on the ISMS performance, incidents, and compliance.
 - Ensure accountability at executive and management levels for security outcomes.
- **Regulatory Compliance Oversight**
 - Verify that the ISMS complies with legal, regulatory, and contractual obligations.
 - Oversee internal and external audits of the ISMS.

Chief Information Security Officer (CISO)

- **Strategic Leadership**
 - Develop and implement the organization-wide cybersecurity strategy.
 - Align security initiatives with business objectives and risk appetite defined by the Board.
 - Ensure cybersecurity is integrated into enterprise risk management and governance frameworks.
- **ISMS Oversight**
 - Lead the development, implementation, and maintenance of the Information Security Management System (ISMS) according to ISO 27001:2022.

- Ensure continuous improvement of the ISMS through regular audits, monitoring, and review.
- **Risk Management**
 - Identify, assess, and prioritize cyber risks across all business units.
 - Develop and oversee mitigation plans to reduce risk to acceptable levels.
 - Report critical risks to executive management and the Board.
- **Incident Response & Crisis Management**
 - Establish and oversee the Incident Response Plan and Security Operations.
 - Lead responses to security incidents, including breaches, ransomware, or insider threats.
 - Coordinate cross-functional teams during crises to minimize business impact.
- **Regulatory Compliance**
 - Ensure compliance with financial regulations, data protection laws, and cybersecurity standards.
 - Serve as the main point of contact for regulatory audits and assessments.
- **Policy and Governance**
 - Develop, approve, and enforce information security policies.
 - Ensure all employees understand and follow security policies.
 - Advise senior management on policy changes, emerging threats, and technological solutions.
- **Vendor and Third-Party Security**
 - Oversee third-party risk management to ensure vendors and partners comply with security standards.
- **Reporting**
 - Provide regular updates to the Board of Directors and executive management on the ISMS, risk posture, incidents, and remediation actions.

Information Security Manager (ISMS Manager)

- **Manage the ISMS:**
 - Oversee the day-to-day operations of the ISMS, ensuring it is effectively implemented and maintained.
- **Handle Security Risk Assessments:**
 - Conduct regular security risk assessments to identify and mitigate potential organisational threats.
- **Ensure Adherence to the ISMS:**
 - Monitor compliance with the ISMS policies and procedures and enforce corrective actions as necessary.
- **Awareness and Training**
 - Promote a security-aware culture across the organization.
 - Ensure ongoing training and awareness programs for employees, contractors, and stakeholders.

IT / Security Operations Team

- **Monitoring & Detection**
 - Operate the Security Operations Center (SOC) or equivalent monitoring systems.
 - Monitor networks, servers, endpoints, and applications for unusual activity or security events.
- **Incident Response**
 - Investigate and respond to security incidents, such as malware infections, phishing attacks, or unauthorized access.
 - Contain and remediate security breaches according to the Incident Response Plan.
 - Document incidents and report them to the CISO and management.
- **Vulnerability Management**
 - Conduct **regular vulnerability scans** on systems, networks, and applications.
 - Apply patches and updates to remediate vulnerabilities.
 - Maintain an up-to-date inventory of assets and their security status.
- **Configuration & Access Management**
 - Ensure secure configuration of servers, endpoints, applications, and network devices.
 - Implement role-based access control (RBAC) and enforce the principle of least privilege.
 - Support line managers and system owners in granting, modifying, or revoking access.
- **Threat Intelligence & Analysis**
 - Analyse current and emerging threats to the bank.
 - Maintain awareness of malware trends, hacking techniques, and attack vectors.
 - Feed threat intelligence into risk assessments and preventive controls.
- **Backup & Recovery Support**
 - Ensure data backups are performed correctly and securely.
 - Participate in disaster recovery tests and help restore systems in case of outages or breaches.
- **Policy & Procedure Enforcement**
 - Implement technical controls mandated by the ISMS, including firewalls, antivirus, DLP, and endpoint protection.
 - Enforce security policies on all bank IT assets.
- **Security Reporting**
 - Provide reports on system health, incidents, and compliance to the Information Security Manager.
 - Maintain logs and evidence for audits and regulatory compliance purposes.

Internal Audit / Compliance Team

- **Audit ISMS and Security Controls**
 - Conduct regular and independent audits of the ISMS and cybersecurity controls.
 - Identify gaps, weaknesses, or non-compliance with ISO 27001:2022 standards, internal policies, and regulatory requirements.
- **Regulatory Compliance Oversight**
 - Ensure adherence to banking regulations, data protection laws, and cybersecurity frameworks.
 - Verify that legal and contractual obligations related to information security are being met.
- **Report Findings and Recommendations**
 - Provide formal audit reports to executive management and the Board.
 - Recommend corrective actions and track their implementation to close compliance gaps.
- **Support Continuous Improvement**
 - Review and assess the effectiveness of security policies, procedures, and controls.

- Provide insights for enhancing the ISMS, risk management, and operational security practices.

Precurement Vendor Team

- **Vendor Risk Assessment**
 - Evaluate the security posture of all third-party vendors before onboarding.
 - Assess vendors' compliance with the bank's security requirements and regulatory standards.
- **Ongoing Vendor Monitoring**
 - Continuously monitor vendors' security performance and compliance.
 - Conduct periodic audits, security reviews, or assessments of critical vendors.
- **Incident Coordination**
 - Manage the response when a vendor-related security incident occurs.
 - Coordinate remediation efforts and ensure proper reporting to internal stakeholders and regulators.
- **Policy and Awareness**
 - Develop and enforce policies for secure vendor management.
 - Educate internal teams about risks associated with third-party services.
- **Security Coordination**
 - All vendor-related security incidents are immediately reported to and managed in coordination with the Security Team.
 - Security Team validates remediation actions, approves critical decisions, and ensures regulatory compliance.
 - Regular communication channels between Procurement Vendor Team and Security Team are maintained for updates on vendor risks, incidents, and policy changes.

Risk Management Department

- **Enterprise Risk Oversight**
 - Maintain the risk register and ensure it is updated with risk treatment plans.
 - Identify, assess, and monitor organizational risks, including operational, financial, cyber, and third-party risks.
- **Risk Assessment & Treatment**
 - Collaborate with the CISO and ISMS Manager to perform risk assessments specific to information security.
 - Recommend risk mitigation strategies and controls aligned with the bank's risk appetite.
- **Reporting & Escalation**
 - Provide regular reports on risk posture, emerging threats, and control effectiveness to executive management and the Board.
 - Escalate critical risks that exceed risk appetite or require immediate attention.
- **Policy & Framework Alignment**
 - Ensure that risk management practices align with ISMS policies, regulatory requirements, and international standards (ISO 31000, COSO ERM).
- **Continuous Improvement**
 - Participate in lessons-learned reviews following incidents or audits.
 - Suggest enhancements to risk identification, assessment, and treatment methodologies.

Security Team

- **Operational Security Management**
 - Implement, monitor, and maintain technical security controls, including firewalls, IDS/IPS, endpoint protection, and DLP solutions.
 - Ensure network, system, and application security configurations are up to date and compliant with ISMS policies.
- **Incident Detection & Response Support**
 - Assist IT/SOC team in detecting and responding to security events.
 - Participate in forensic analysis, containment, and remediation of security incidents.
- **Threat Intelligence & Monitoring**
 - Monitor emerging cyber threats and vulnerabilities.
 - Provide actionable threat intelligence to IT/SOC and Risk Management teams.
- **Policy Enforcement & Audit Support**
 - Enforce security policies at the operational level.
 - Assist in internal and external audits by providing evidence and reports.
- **Access & Privilege Management**
 - Support IT/SOC in access provisioning, privilege review, and revocation according to RBAC and least privilege principles.
- **Training & Awareness Support**
 - Assist in security awareness programs by providing operational insights and incident examples.

All Staff

- **Comply with Policies and Procedures:**
 - Follow all security policies and procedures as outlined by the ISMS.
- **Report Policy Breaches:**
 - Promptly report any security incidents or breaches to the appropriate authority.
- **Seek Exceptions via IT Helpdesk:**
 - Request any necessary exceptions to security policies through the IT Helpdesk.

Responsibility Assignment Matrix (RACI)

Activity	Board of Directors	Chief Information Security Officer	Information Security Manager	IT / Security Operations Team	Internal Audit / Compliance Team	Third-Party / Vendor Security Manager	Risk Management Department	Security Team	All Staff
Approve Security Policies	A	C	R	I	C	I	C	C	I
Oversee ISMS Framework	A	R	C	I	C	C	C	C	I
Conduct Risk Assessments	I	A	R	I	C	C	R	C	I
Ensure ISMS Compliance	I	A	R	C	R	C	C	R	I
Manage Security Risks	I	A	R	R	C	C	R	C	I
Grant Access	I	C	R	R	I	I	C	R	I
Report Policy Breaches	I	C	R	I	I	I	I	R	R
Seek Policy Exceptions	I	C	R	I	I	I	C	C	R
Develop and Maintain Security Policies	I	A	R	C	C	C	C	C	I
Security Awareness Training	I	C	R	I	C	I	I	R	I
Incident Response and Management	I	A	R	R	C	C	C	R	I
Access Review and Audit	I	C	R	R	A	I	C	R	I
Third-Party Risk Management	I	A	R	I	C	R	R	C	I
Security Metrics and Reporting	A	R	C	C	I	I	R	R	I
Data Protection and Privacy Compliance	I	A	R	C	R	C	C	R	I

Legend:

- **R** = Responsible
- **A** = Accountable
- **C** = Consulted
- **I** = Informe

